Documentación Sprint 2 - HELIOS

Sistema: HELIOS - Citas Médicas Unificadas **Materia:** Calidad de Software - UTP 2026
Sprint: 2 (en curso) - Bugs urgentes + Cancelación/Reprogramación + Testing **Fecha:** junio 2026

---

1. Resumen

Tras la demo del Sprint 1, el Product Owner detectó en producción un bug del calendario (desfase de hora) y pidió reforzar la validación de datos del registro para evitar errores humanos, priorizando la seguridad y que el sistema "no se rompa nunca". Este documento describe los 4 bugs corregidos (B-21 a B-24), la investigación de los tipos de cédula panameña, y el plan de pruebas de seguridad (OWASP ZAP) y rendimiento (Lighthouse).

Resultado: 117/117 tests pasando, bundle 503 KB (bajo de 754), cancelar y reprogramar citas en produccion, hueco de seguridad RLS cerrado, y cero regresiones del Sprint 1.

---

2. Bug B-21 - Calendario: desfase de hora (zona horaria)

Síntoma

En el calendario de agendamiento aparecía un horario (ej. 12:30 PM) pero al seleccionarlo el bloque se posicionaba/interpretaba en otra hora. El usuario creía agendar a una hora distinta de la mostrada.

Causa raíz

La vista de desktop usaba la librería **FullCalendar**, que construye los eventos a partir de cadenas ISO sin zona horaria:

```
start: `${horario.fecha}T${horario.hora_inicio}`   // ej. "2026-06-15T12:30:00"
```

JavaScript convierte esa cadena a un objeto `Date` aplicando el desfase de la zona horaria del navegador (Panamá es UTC-5). Por eso el bloque visual no coincidía con el título del

slot. (La vista móvil NO tenía el bug porque mostraba la hora con un corte de texto directo, sin convertir a `Date`.)

Además, `useHorarios` y `useMedicoCitas` calculaban "hoy" con `new Date().toISOString()`, que devuelve la fecha en UTC: después de las 7 PM en Panamá eso adelantaba al día siguiente y podía ocultar slots de hoy.

Solución

- Usar **siempre la vista de botones por día** (la misma de móvil, ya probada), tanto en móvil como en desktop. Esta vista muestra y selecciona la hora con un corte de texto (`hora_inicio.slice(0,5)`), sin pasar por `Date`, por lo que es 100% segura ante zonas horarias y nunca puede desfasar la hora.
- Se eliminó la dependencia de FullCalendar -> el bundle bajó de **754 KB a 496 KB** (-34 %).
- `useHorarios` y `useMedicoCitas` ahora calculan la fecha local a mano (año-mes-día), sin `toISOString()`.

Verificación

Test automatizado: un slot con `hora_inicio = "12:30:00"` se muestra como "12:30" y al elegirlo se pasa exactamente ese horario (no 07:00 ni otra hora).

---

3. Bug B-22 - Validación de cédula panameña (5 tipos)

Síntoma

El validador rechazaba cédulas válidas cortas. Ejemplo real: `PE-5-687` (un panameño nacido en el extranjero) quedaba en 4 dígitos al quitar el prefijo y se rechazaba, aunque es una cédula legítima.

Investigación: tipos de cédula en Panamá

Según el **Tribunal Electoral de Panamá**, existen estos tipos:

Tipo	Formato	Ejemplo	Descripción
Natural (por nacimiento)	clave(1-13)-tomo-asiento	8-926-1601	Panameño (provincia o comarca)
PE	PE-tomo-asiento	PE-5-687	Panameño nacido en el extranjero
N	N-tomo-asiento	N-19-473	Naturalizado
E	E-provincia-orden	E-8-74258	Extranjero domiciliado
PI	PI-tomo-asiento	PI-12-3456	Indígena / comarca

- El primer numero de la cedula (la "clave") va del **1 al 13**, e incluye las **10 provincias + 3 comarcas indigenas** (NO son 13 provincias). Codigos 1-9 = provincias originales (8 = Panama), 10-12 = comarcas (Guna Yala, Embera, Ngabe-Bugle), 13 = Panama Oeste (la 10a provincia, creada en 2014; le toco el 13 por ser la ultima en agregarse).
- El tomo y el asiento son numéricos y de longitud variable (por eso hay cédulas con menos dígitos).

Solución

Se reescribió `lib/cedula.ts` para validar la **estructura por tipo** (no un conteo rígido de dígitos), con un fallback permisivo de dígitos puros (5-13) para no rechazar nunca una cédula real escrita sin guiones. Se agregaron: - `detectarTipoCedula()`: muestra al usuario el tipo detectado mientras escribe. - `EJEMPLOS_CEDULA`: ejemplos por tipo que ahora se muestran en el formulario.

Fuentes consultadas

- Tribunal Electoral de Panamá - La Cédula: https://www.tribunal-electoral.gob.pa/direccion-nacional-de-cedulacion/la-cedula/
- Dirección Nacional de Cedulación: https://www.tribunal-electoral.gob.pa/direccion-nacional-de-cedulacion/
- Significado de letras en cédulas panameñas (referencia): https://panama50.com/significado-letras-cedulas-panamenas/

---

4. Bug B-23 - Doble confirmación de cédula y contraseña

Para evitar errores de tipeo (que generaban pacientes con cédula equivocada), el formulario de registro ahora pide escribir **dos veces** la cédula y la contraseña; ambas deben coincidir o el registro se bloquea con un mensaje claro. El campo "Confirmar cédula" tiene el pegado (paste) deshabilitado para forzar la re-escritura real y detectar errores.

---

5. Bug B-24 - Validación de teléfono, nombre y correo

Nuevo módulo `lib/validaciones.ts`:

Campo	Regla	Rechaza
Teléfono	Móvil 8 dígitos / fijo 7, opcional +507	letras, símbolos raros
Nombre	Solo letras (con acentos), espacios, apóstrofo, guion, punto; 2-80	números, @, #, etc.
Correo	Formato estándar correo@dominio.ext	espacios, doble @, sin dominio

Los inputs usan `inputMode`/`type` correctos para mostrar el teclado adecuado en móvil. El teléfono es opcional, pero si se ingresa se valida.

---

6. Bug B-25 - No agendar slots de hoy cuya hora ya pasó

Síntoma

El calendario dejaba seleccionar un horario de HOY cuya hora **ya había pasado** (ej. 7:00 AM cuando ya era de tarde).

Causa raíz

El filtro de carga de horarios solo excluía **días** pasados (`fecha >= hoy`), pero no las **horas** pasadas del día de hoy. Por eso los slots tempranos de hoy seguían apareciendo aunque ya no fueran agendables.

Solución

Nueva función pura `filtrarSlotsFuturos(horarios, ahora)` que descarta los slots con `fecha === hoy` y `hora_inicio <= horaActual`. La comparación es 100% local en strings (formatos `YYYY-MM-DD` y `HH:MM:SS` con ceros a la izquierda, donde el orden alfabético coincide con el cronológico), sin usar `Date`/UTC, consistente con el fix de zona horaria B-21.

Nota

Es un filtro de **frontend**: oculta los slots vencidos del calendario. Los registros siguen en la base de datos como `disponible=true`; si se quisiera una limpieza real en BD (marcar `disponible=false` a los vencidos), sería una tarea SQL aparte. Para el uso normal, ocultarlos del calendario es suficiente.

Verificación

Test `useHorarios.test.ts`: slot de hoy 7 AM se descarta, slot de hoy 6 PM se mantiene, días futuros se mantienen.

---

7. Funcionalidad: Cancelar y Reprogramar citas (HELL-3)

Es el corazon del Sprint 2: permitir al paciente gestionar sus citas sin llamar al centro medico.

Backend (SQL, SECURITY DEFINER) — supabase/migrations/sprint2_cancelar_reprogramar.sql

- **cancelar_cita_atomica(p_cita_id):** valida que la cita sea del paciente (via auth_paciente_link), cambia estado a 'cancelada' y libera el horario. Todo en una transaccion (atomico).
- **reprogramar_cita_atomica(p_cita_id, p_nuevo_horario_id):** valida dueño + que el nuevo horario sea del mismo medico y este disponible; libera el viejo, reserva

el nuevo y actualiza la cita. Usa FOR UPDATE para que dos pacientes no tomen el mismo slot (anti-condicion de carrera).

- **citas_historial + trigger:** registra automaticamente cada cambio (creada/cancelada/reprogramada/completada/no_asistio) con actor y fecha.

Fix critico (code review)

`citas.horario_id` tenia un `UNIQUE` TOTAL. Al cancelar dejabamos estado= 'cancelada' pero el horario_id seguia apuntando al slot, asi que re-reservarlo o reprogramar hacia el violaba el UNIQUE y el slot quedaba inutilizable para siempre. **Fix:** indice unico PARCIAL (`WHERE estado <> 'cancelada'`), asi un slot liberado se puede volver a usar.

Frontend

- Hooks `useCancelarCita` / `useReprogramarCita` (withTimeout + manejo de error).
- `BotonCancelarCita`: boton + modal de confirmacion (accion no reversible).
- `ReprogramarCitaModal`: modal que reutiliza el calendario timezone-safe (B-21).
- `MisCitas`: badges de estado por color + botones solo en citas confirmadas.
- Dashboard medico: la agenda de "hoy" ya no muestra las canceladas.

Tests

9 nuevos: hooks (cancelar/reprogramar OK + error + timeout), componente boton, y la UI de MisCitas (botones segun estado + apertura del modal).

---

8. Bug B-26 - Seguridad: cerrar hueco RLS sprint1_all

Problema

El schema.sql creo policies permisivas `sprint1_all` (FOR ALL USING(true)) en 7 tablas. B-14 agrego policies estrictas pero NO borro las permisivas. Como las policies se combinan con OR, mientras existiera `sprint1_all` cualquier usuario autenticado podia leer, modificar o borrar datos ajenos por la API directa. Verificado por el PO: las 7 tablas tenian la policy permisiva.

Solucion (supabase/migrations/sprint2_b26_cerrar_sprint1_all.sql)

Migracion transaccional (BEGIN/COMMIT) que: 1. Re-crea (idempotente) TODAS las policies estrictas de B-14 -> garantiza que existen antes de quitar la permisiva (no se rompe el acceso legitimo). 2. Elimina las `sprint1_all` de las 7 tablas. Incluye un ROLLBACK de emergencia comentado y una query de verificacion.

Importante

NO borra datos, usuarios ni contraseñas — solo cambia REGLAS de permiso. La tabla auth.users queda intacta; las cuentas siguen funcionando igual.

Pendiente menor (Sprint 5)

La policy `chequeo_cedula_en_registro` (SELECT true en pacientes, para el chequeo de cedula duplicada en el registro) es un read-leak menor. Se movera a una RPC. NO es el hueco critico (ese era de ESCRITURA, ya cerrado).

---

9. Pruebas de seguridad - OWASP ZAP

Aclaración importante: el sitio `zapitmedical.com` que se mencionó NO es una herramienta de testing (es un producto de cumplimiento de seguridad radiológica para hospitales). La herramienta correcta para pruebas de seguridad es **OWASP ZAP (Zed Attack Proxy)**, que fue la que mencionó la profesora.

Cómo ejecutar un escaneo baseline (no intrusivo)

Requiere Docker. No modifica datos de producción.

```
docker run -t zaproxy/zap-stable zap-baseline.py \
  -t https://helios-web-production.up.railway.app \
  -r zap_report.html
```

Qué revisa

- Cabeceras de seguridad (CSP, X-Frame-Options, HSTS, etc.)
- Cookies (flags Secure/HttpOnly)
- Exposición de información, formularios sin protección, etc.

Interpretación

Muchas alertas del baseline son **informativas** (faltan cabeceras recomendadas). Se documentan por severidad y se priorizan: las cabeceras de seguridad se pueden agregar

en el `Dockerfile`/servidor en una tarea de hardening. **No** rompe producción porque el baseline solo navega, no ataca.

---

10. Pruebas de rendimiento - Lighthouse

Cómo ejecutar

Desde Chrome: DevTools -> pestaña Lighthouse -> Analyze. O por línea de comandos:

```
npx lighthouse https://helios-web-production.up.railway.app \
  --output html --output-path lighthouse_report.html
```

Métricas que captura

- **LCP** (Largest Contentful Paint) - cuándo carga el contenido principal
- **CLS** (Cumulative Layout Shift) - estabilidad visual
- **TBT** (Total Blocking Time) - bloqueo del hilo principal
- Puntajes de Performance, Accessibility, Best Practices y SEO

El bundle reducido en B-21 (754 -> 496 KB) ayuda directamente al LCP y al TBT.

---

11. Subtareas para Jira (HELL-3) - listas para pegar

> *Nota: el asistente no tiene conectado el MCP de Atlassian, así que estas subtareas se entregan como texto para copiar/pegar en la issue HELL-3.*

Orden de ejecución: bugs urgentes primero, luego testing, luego cancelar/reprogramar.

ID	Subtarea	SP	Responsable	Estado sugerido
ST-10	Fix calendario zona horaria (vista botones desktop) [B-21]	3	Ethan	Done
ST-11	Validador cédula 5 tipos + ejemplos + detección [B-22]	3	Ethan/Alejandro	Done
ST-12	Doble confirmación cédula y contraseña [B-23]	2	Ethan	Done

ID	Subtarea	SP	Responsable	Estado sugerido
ST-13	Validación teléfono/nombre/correo [B-24]	2	Ethan	Done
ST-16	No agendar slots de hoy ya vencidos [B-25]	1	Ethan	Done
ST-17	Cerrar hueco RLS sprint1_all [B-26]	2	Alejandro	Done
ST-14	Pruebas de seguridad OWASP ZAP + documentar	3	Ashley/Marian	To Do (Sprint 5)
ST-15	Pruebas de rendimiento Lighthouse + documentar	2	Ashley	To Do
ST-1	Función SQL cancelar_cita_atomica	2	Alejandro	To Do
ST-2	Función SQL reprogramar_cita_atomica	3	Alejandro	To Do
ST-3	Tabla citas_historial + triggers	2	Alejandro	To Do
ST-4	Hook useCancelarCita	1	Ethan	To Do
ST-5	Componente BotonCancelarCita + modal	1	Ethan	To Do
ST-6	Hook + página ReprogramarCita	3	Ethan	To Do
ST-7	Actualizar MisCitas con botones	1	Ethan	To Do
ST-8	Actualizar dashboard médico	1	Ethan/Ashley	To Do
ST-9	Tests E2E + smoke post-deploy	-	Ashley/Marian	To Do

> ***Estado actual (al cierre del Sprint 2):*** *ST-10 a ST-13, ST-16 y ST-17 (bugs + seguridad) estan* ***DONE****. ST-1 a ST-9 (cancelar/reprogramar) tambien estan* ***DONE*** *(BD ejecutada +*

> *frontend desplegado + 117 tests). Solo quedan ST-14 y ST-15 (OWASP ZAP + Lighthouse) para el Sprint 5 "Pruebas y cierre".*

Descripción sugerida para HELL-3 (pegar en el campo Description)

```
OBJETIVO SPRINT 2
Arreglar bugs urgentes de producción (calendario y validaciones) y luego
habilitar cancelar/reprogramar citas. Reforzar la calidad con pruebas de
seguridad (OWASP ZAP) y rendimiento (Lighthouse).

ALCANCE
1. [B-21] Fix calendario: desfase de hora por zona horaria
2. [B-22] Cédula: aceptar los 5 tipos panameños + ejemplos
3. [B-23] Doble confirmación de cédula y contraseña
4. [B-24] Validación de teléfono, nombre y correo
5. Pruebas OWASP ZAP (seguridad) + Lighthouse (rendimiento)
6. Cancelar y reprogramar cita (autoservicio del paciente)

CRITERIOS DE ACEPTACIÓN
- El calendario muestra y agenda la MISMA hora (sin desfase)
- Se aceptan cédulas PE/N/E/PI además de las naturales
- No se puede registrar con cédula/contraseña que no coincidan
- Teléfono/nombre/correo se validan antes de enviar
- 100% de los tests del Sprint 1 siguen pasando (cero regresiones)
```

---

12. Verificación

- `pnpm vitest run` -> 117/117 tests pasan
- `pnpm build` -> limpio; bundle 496 KB (bajó de 754 KB)
- Manual: agendar un slot "12:30" -> en "Mis Citas" se ve 12:30
- Registro: PE-5-687 aceptada; cédula que no coincide -> rechazada; teléfono con letras -> rechazado; nombre con números -> rechazado; ejemplos de cédula visibles

---

Documento generado para el Sprint 2 de HELIOS - UTP Calidad de Software 2026.